

Marco Integrativo GQM + PRAGMATIC

Aplicado a indicadores PASTA+STRIDE en clave nacional (España)

1. Introducción

Este marco integra:

- GQM (Goal–Question–Metric), que obliga a partir de objetivos claros, traducirlos en preguntas y sólo entonces escoger métricas.[web:45][web:46][web:51]
- PRAGMATIC, que proporciona nueve criterios para evaluar la utilidad real de cada métrica: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna (Timely), Independiente y Rentable (Cheap).[web:50][web:52][web:58]

El objetivo es evitar la patología clásica: coleccionar datos técnicos sin conexión con los objetivos nacionales de ciberseguridad, o recitar objetivos altisonantes sin un dato duro que llevarse a la boca.

2. Objetivos nacionales de referencia (capa “G” de GQM)

Tomando como base las estrategias españolas y europeas (Plan Nacional de Ciberseguridad, España Digital, NIS2, etc.), podemos sintetizar cuatro objetivos estratégicos de alto nivel.[web:21][web:27][web:30][web:56]

1.

G1 – Proteger infraestructuras y servicios esenciales

Reducir la frecuencia e impacto de ciberataques graves sobre servicios esenciales y operadores críticos.

2.

G2 – Aumentar la madurez y cobertura del enfoque basado en riesgo

Extender y profundizar el uso de metodologías de análisis y modelado de amenazas (PASTA, STRIDE, etc.) en organizaciones clave.

3.

G3 – Mejorar la resiliencia operativa y la capacidad de recuperación

Reducir los tiempos de indisponibilidad y acelerar la recuperación ante incidentes graves.

4.

G4 – Optimizar la eficiencia económica de la inversión en ciberseguridad

Alinear la inversión con la reducción de riesgo real y con el retorno social/empresarial de dicha inversión.

G1 – Proteger infraestructuras y servicios esenciales

Reducir la frecuencia e impacto de ciberataques graves sobre servicios esenciales y operadores críticos.

G2 – Aumentar la madurez y cobertura del enfoque basado en riesgo

Extender y profundizar el uso de metodologías de análisis y modelado de amenazas (PASTA, STRIDE, etc.) en organizaciones clave.

G3 – Mejorar la resiliencia operativa y la capacidad de recuperación

Reducir los tiempos de indisponibilidad y acelerar la recuperación ante incidentes graves.

G4 – Optimizar la eficiencia económica de la inversión en ciberseguridad

Alinear la inversión con la reducción de riesgo real y con el retorno social/empresarial de dicha inversión.

Todas las combinaciones GQM+PRAGMATIC que siguen se enganchan explícitamente a alguno de estos cuatro objetivos.

3. Recordatorio: indicadores PASTA+STRIDE del informe previo

Del informe PASTA anterior centrándonos en España, extraemos los bloques de indicadores sobre los que vamos a aplicar GQM:

5. Cobertura de modelado de amenazas (porcentaje de organismos/operadores que aplican PASTA/STRIDE u otras metodologías de Threat Modeling).[web:18][web:21]
6. Métricas STRIDE agregadas a nivel país (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) basadas en incidentes reportados.[web:18][web:21][web:28]
7. Madurez de simulación de ataques (porcentaje de operadores que realizan simulaciones/ejercicios basados en modelos de amenazas).[web:18][web:21]
8. Resiliencia y continuidad (tiempo medio de recuperación de servicios esenciales ante incidentes muy graves).[web:21]
9. Integración con gestión de riesgo y continuidad (porcentaje de entidades que incorporan resultados de modelado de amenazas en sus procesos formales de riesgo y continuidad).[web:8][web:21][web:31]

Cada indicador será refinado mediante GQM y sus métricas evaluadas con PRAGMATIC.

4. Aplicación de GQM a los indicadores PASTA+STRIDE

4.1. Indicador 1 – Cobertura del modelado de amenazas

Objetivo (G1, G2)

Incrementar el porcentaje de operadores esenciales y organismos clave que utilizan modelado de amenazas basado en PASTA/STRIDE u otros marcos, para mejorar la identificación y priorización de riesgos.[web:18][web:21][web:39]

Preguntas (Q)

- Q1.1: ¿Qué proporción de organizaciones críticas realiza modelado de amenazas en sus sistemas esenciales?
- Q1.2: ¿Con qué frecuencia se revisan/actualizan los modelos de amenazas?
- Q1.3: ¿En qué fases del ciclo de vida (diseño, desarrollo, operación) se aplica el modelado de amenazas?

Métricas (M)

- M1.1: Porcentaje de operadores de servicios esenciales (OSE) y entidades NIS2 que declaran usar al menos una metodología de modelado de amenazas en sus sistemas críticos.
- M1.2: Porcentaje de esos OSE que realizan al menos una revisión anual de modelos de amenazas.
- M1.3: Porcentaje de proyectos críticos en los que el modelado de amenazas se realiza durante la fase de diseño.

Cada métrica se pondera para construir un “Índice de Cobertura de Threat Modeling” a nivel nacional o sectorial.

4.2. Indicador 2 – Métricas STRIDE agregadas

Objetivo (G1)

Reducir el volumen y la gravedad de incidentes de Spoofing, Tampering, Repudiation, Information Disclosure, DoS y Elevation of Privilege que afectan a servicios esenciales y datos sensibles.[web:18]
[web:21][web:28]

Preguntas (Q)

- Q2.1: ¿Cuál es la incidencia anual de cada categoría STRIDE en servicios esenciales?
- Q2.2: ¿Qué sectores presentan mayor densidad de incidentes por categoría STRIDE?
- Q2.3: ¿Cómo evoluciona esta incidencia en el tiempo tras desplegar medidas o marcos nacionales?

Métricas (M)

- M2.1.x: Número de incidentes significativos por categoría STRIDE ($x \in \{S, T, R, I, D, E\}$) por año en servicios esenciales, normalizado por número de entidades o por tamaño de población atendida.
- M2.2.x: Tasa de incidentes por categoría STRIDE por sector (número de incidentes / número de organizaciones del sector).
- M2.3.x: Tendencia (variación porcentual anual) de cada categoría STRIDE en un periodo de 3–5 años.

4.3. Indicador 3 – Madurez de simulación de ataques

Objetivo (G1, G3)

Incrementar la proporción de organizaciones críticas que realizan simulaciones de ataque y ejercicios basados en modelos de amenazas (PASTA), para mejorar la preparación ante incidentes reales.[web:18]
[web:21]

Preguntas (Q)

- Q3.1: ¿Qué porcentaje de organizaciones realiza simulaciones de ataque al menos anuales?
- Q3.2: ¿Qué alcance tienen los ejercicios (número de sistemas, escenarios, actores implicados)?
- Q3.3: ¿En qué medida esos ejercicios dan lugar a cambios arquitectónicos y de proceso?

Métricas (M)

- M3.1: Porcentaje de OSE y organismos clave que realizan al menos un ejercicio de ciber crisis/red teaming/simulación PASTA al año.
- M3.2: Número medio de sistemas o servicios críticos cubiertos por ejercicio.
- M3.3: Porcentaje de ejercicios que generan planes de acción formalmente aprobados e implementados en un plazo de X meses.

4.4. Indicador 4 – Resiliencia y continuidad (tiempo de recuperación)

Objetivo (G1, G3)

Reducir el tiempo medio de recuperación de servicios esenciales tras incidentes graves, aumentando la resiliencia estructural del país.[web:21]

Preguntas (Q)

- Q4.1: ¿Cuál es el tiempo medio de restablecimiento de servicios esenciales tras incidentes muy graves?
- Q4.2: ¿Existen diferencias significativas por sector y nivel de madurez en modelado de amenazas?
- Q4.3: ¿Disminuye este tiempo con la implantación de prácticas avanzadas de PASTA/STRIDE y ejercicios de simulación?

Métricas (M)

- M4.1: Tiempo medio de recuperación (MTTR crítico) de servicios esenciales tras incidentes clasificados como “muy graves”.
- M4.2: Distribución del MTTR por sector.
- M4.3: Correlación entre el MTTR y el nivel de madurez en Threat Modeling/ejercicios de simulación (por quintiles de IGM).

4.5. Indicador 5 – Integración en gestión de riesgo y continuidad

Objetivo (G2, G3, G4)

Asegurar que los resultados de PASTA/STRIDE se integran en los procesos de gestión de riesgo, continuidad de negocio y presupuestación, para orientar decisiones de inversión.[web:8][web:31]

Preguntas (Q)

- Q5.1: ¿Qué porcentaje de entidades integra formalmente resultados de Threat Modeling en sus matrices de riesgo corporativo?
- Q5.2: ¿Se vinculan dichos resultados a planes de continuidad y ejercicio de crisis?
- Q5.3: ¿Se usan para justificar inversiones y medir ROI?

Métricas (M)

- M5.1: Porcentaje de entidades que declara integrar resultados de Threat Modeling en su metodología formal de riesgo.
- M5.2: Porcentaje de entidades que vincula escenarios PASTA con planes de continuidad y ejercicios.
- M5.3: Porcentaje de entidades que declara usar resultados de Threat Modeling en análisis de ROI/decisiones de inversión.

5. Evaluación PRAGMATIC (visión general)

Cada métrica anterior se evaluará con una escala 1–5 en los nueve criterios PRAGMATIC, permitiendo priorizar las más útiles.[web:50][web:52][web:58]

Ejemplo (resumido, los detalles van en la matriz específica):

- M1.1 (porcentaje de OSE con Threat Modeling): alta relevancia, accionabilidad y significatividad; coste razonable.
- M2.1.x (incidentes STRIDE): alta predictividad y relevancia, pero puede sufrir problemas de precisión y genuinidad si la notificación es incompleta.
- M4.1 (tiempo medio de recuperación): extremadamente relevante y significativa, pero más cara de obtener y sensible a datos incompletos.

6. Uso del marco integrativo

10. Partir de objetivos nacionales (G).
11. Formular preguntas que pueda entender un ministro, un regulador y un CISO a la vez (Q).
12. Seleccionar métricas técnicas que de verdad respondan a esas preguntas (M).
13. Pasar las métricas por el filtro PRAGMATIC antes de invertir en capturarlas masivamente.
14. Revisar periódicamente la cartera de métricas, retirando las que no cumplen y adoptando nuevas según cambien objetivos y contexto.

Con esto, los indicadores dejan de ser un catálogo de cifras desconectadas y pasan a formar parte de una narrativa coherente: desde la protección de infraestructuras críticas hasta el dato técnico más pedestre que hay que picar en una base de datos.